

NovaTech Solutions

IT Security Policy

Information Security Standards & Acceptable Use

Version 5.0 · Effective 1 February 2025 · Issued by Human Resources

Information Technology Security Policy

This policy defines NovaTech's standards for protecting company data, systems, and infrastructure. All employees, contractors, and third-party vendors with access to NovaTech systems must comply. Non-compliance may result in disciplinary action including termination and legal proceedings.

1. Access Control & Authentication

Access to NovaTech systems is granted on the principle of **least privilege**: employees receive only the permissions necessary for their role. Access rights are reviewed quarterly by IT and the relevant team lead.

- All passwords must be at least **14 characters** and include uppercase, lowercase, numbers, and symbols.
- Passwords must be changed every **90 days**. Previous 12 passwords cannot be reused.
- Password sharing is strictly prohibited — each user must have their own credentials.
- **Multi-Factor Authentication (MFA)** is mandatory for all company accounts including email, VPN, and cloud services.
- Hardware security keys (YubiKey) are provided to all employees with access to production systems.
- Failed login attempts: 5 consecutive failures will lock the account. Contact IT Helpdesk to unlock.
- Shared/service accounts require approval from the CISO and are audited monthly.

2. Device Security

All company-issued devices (laptops, mobile phones, tablets) must comply with the following standards at all times. Personal devices may only access company data via the approved MDM (Mobile Device Management) solution.

- **Full-disk encryption** (BitLocker / FileVault) is mandatory on all laptops.
- Devices must have the latest approved OS and security patches within **72 hours** of release.
- Antivirus/EDR software (CrowdStrike Falcon) must remain active and cannot be disabled.
- Screen lock must activate after **5 minutes** of inactivity (2 minutes on mobile).
- Lost or stolen devices must be reported to IT Security within **1 hour** of discovery.
- Personal USB storage devices are prohibited. IT-approved encrypted USB drives may be requested.
- Connecting to public/hotel Wi-Fi requires VPN (GlobalProtect) to be active.

3. Data Classification & Handling

NovaTech uses a four-tier data classification system. Employees must understand and apply the correct handling procedures.

Classification	Examples	Can Be Emailed?	Can Be Shared Externally?
Public	Press releases, job postings	Yes	Yes
Internal	Policies, meeting notes, roadmaps	Yes (internal)	No
Confidential	Client data, contracts, source code	Encrypted only	With NDA only
Restricted	PII, financial records, auth credentials	Encrypted + approval	Never

4. Acceptable Use

Company IT resources are provided for business purposes. Limited personal use is tolerated provided it does not impact productivity, consume excessive bandwidth, or expose the company to risk.

- Prohibited: accessing illegal content, torrenting, mining cryptocurrency, running personal businesses.
- Prohibited: installing unlicensed software or any software not approved by IT.
- Prohibited: disabling or circumventing security controls (VPN, MFA, antivirus).
- Allowed: brief personal browsing, messaging family, streaming music at low bandwidth during breaks.
- All internet activity on company devices is monitored and logged for security purposes.
- Social media use during work hours should be limited and must not represent NovaTech without explicit PR approval.

5. Incident Reporting

Employees must report any suspected security incident immediately — including phishing emails, malware, unauthorised access, or data loss. Early reporting significantly limits damage.

- Report via: security@novatech.io or call the IT Security Hotline: +968-2400-0911 (24/7).
- Initial report must be made within **1 hour** of discovery.
- Do not attempt to investigate or remediate a suspected breach independently.
- Employees who report in good faith are protected from retaliation, even if the report turns out to be a false alarm.
- Failure to report a known incident may result in personal liability and disciplinary action.

Note: NovaTech runs quarterly phishing simulation campaigns. Employees who fail 3 simulations in a row will be required to complete mandatory security awareness training.
